

INCIDENT RESPONSE REPORT

Operation Midnight Helpdesk

Confidential — Prepared per NIST SP 800-61r2

Incident Name	Operation Midnight Helpdesk
Incident Reference	NPT-2026-0421-01
Reported By	Mark Smith, Finance
Received	22 April 2026, 09:14 UTC — "My machine was throwing login prompts at me through the night. I ignored it and went back to sleep. Seems fine this morning."
Focus Window (UTC)	22 April 2026, 04:30 – 06:00
Primary Host	npt-ws01 — confirmed compromised
Secondary Host	npt-srv01 — lateral-movement target, attempt blocked
Incident Window (local, source telemetry)	Apr 21, 2026 ~6:34 PM – Apr 22, 2026 ~2:00 AM
NIST 800-61 Phases Covered	Detection & Analysis; Containment, Eradication & Recovery; Post-Incident Activity

1. Executive Summary

An external attacker gained access to workstation npt-ws01 using valid credentials for the account "helpdesk" from IP address 20.110.92.50. The attacker deployed a malicious implant (WindowsUpdate.exe, detected as the "Gracing" malware family) via remote WMI execution, established multiple layers of persistence (registry Run key, scheduled task, and Windows service), created a backdoor local administrator account (nexus_admin), disabled/evaded Microsoft Defender protections, conducted internal discovery and credential-access activity, and beacons to an external command-and-control domain (updates.abordasync.website). The attacker also attempted to pivot to a second host, npt-srv01, via RDP, WMI, and a PowerShell-deployed payload; this lateral-movement attempt was detected and blocked by AMSI/Microsoft Defender before it could establish persistence.

This investigation was opened from a single line in a helpdesk ticket: Mark Smith (Finance) reported that his machine, npt-ws01, "was throwing login prompts at me through the night," which he dismissed and went back to sleep. Those repeated prompts correspond directly to the sustained cluster of brute-force / credential-access alerts logged between 11:35 PM and 1:53 AM — what looked like a routine nuisance was the attacker actively working to expand access on an already-compromised host. The account confirms the finding rather than merely prompting it.

2. What Happened

Initial access was achieved through a successful network logon using the "helpdesk" account, sourced from an external IP address, rather than through exploitation of a vulnerability. Once on npt-ws01, the attacker moved quickly to disable endpoint defenses (multiple "Attempt to turn off Microsoft Defender Antivirus protection" and AV-exclusion alerts) before launching their implant. The implant's launch command (`cmd.exe /Q /c start "" "C:\Windows\Temp\WindowsUpdate.exe" 1> \Windows\Temp\uYgvso 2>&1`) was spawned by `wmiprvse.exe`, confirming remote WMI-based execution rather than an interactive local session — a hands-on-keyboard remote attacker, not an insider at the console.

The dropped implant was recovered and hashed: SHA256 20cef6a013953890f9d38605d25d60dd63b42b09946bbb18ddb4a456da306e77 for `C:\Windows\Temp\WindowsUpdate.exe`. This hash is the definitive identifier for the implant and is used for fleet-wide detection, independent of filename or path, both of which are trivially changed by the attacker.

The attacker then layered in redundant persistence — a registry Run key (`WindowsHealthCheck`), a scheduled task (`GoogleUpdaterTask`), and a disguised Windows service (`WindowsHealthSvc`, presented with the display name "Windows Health Service") — alongside a backdoor local administrator account (`nexus_admin`). Discovery commands enumerated network shares, domain trusts, and accounts, and multiple credential-access (brute-force) alerts followed, consistent with an attempt to harvest or validate additional credentials for further movement. The host beacons outbound to `updates.abordasync.website`, consistent with an established command-and-control channel.

Approximately three hours into the intrusion, the attacker attempted to extend their foothold to a second host, `npt-srv01` (10.3.0.10), using RDP and WMI, and by deploying a payload via an Azure RunScript-style mechanism. This attempt was caught by AMSI/Microsoft Defender, which prevented the payload from executing. No persistence, account creation, or discovery activity followed on `npt-srv01`, indicating the lateral-movement attempt did not succeed in establishing a foothold there — though containment review has still been extended to that host as a precaution.

3. Timeline

Time (local)	Host	Event
Prior to 6:34 PM	npt-ws01	Attacker authenticates successfully via a Network logon using the "helpdesk" account, sourced from external IP 20.110.92.50.
6:34–6:38 PM	npt-srv01	Attacker attempts to extend access via an Azure RunScript-deployed payload (Remote Services / PowerShell). AMSI/Defender blocks the "MpTamperBulkExcl" payload before execution; no persistence follows.
~7:49 PM	npt-ws01	Multiple attempts to disable Microsoft Defender and add AV exclusions. WMI-initiated <code>cmd.exe</code> launches the implant: <code>C:\Windows\Temp\WindowsUpdate.exe</code> , spawned by <code>wmiprvse.exe</code> (remote WMI execution, not local user activity).
~7:49 PM	npt-ws01	Implant confirmed dropped to <code>C:\Windows\Temp\WindowsUpdate.exe</code> ; SHA256 20cef6a013953890f9d38605d25d60dd63b42b09946bbb18ddb4a456da306e77 recovered for attribution and blocklisting.
8:03 PM	npt-ws01	Suspicious account creation and Windows account manipulation activity begins (early persistence/privilege-escalation staging).

8:48 PM	npt-ws01	Backdoor local account "nexus_admin" created via net user and added to the local Administrators group.
10:59–11:18 PM	npt-ws01 → npt-srv01 (10.3.0.10)	npt-ws01 initiates outbound RDP (3389) to npt-srv01; PowerShell script19.ps1 runs; WMI (Winmgmt) and RPC/TermService activity observed — the lateral-movement pivot attempt toward the second host.
11:18 PM	npt-ws01	"Gracing" malware detected and active; lateral-movement techniques logged (SMB Admin Shares, WinRM, WMI, DCOM); a file is dropped and launched from a remote location.
11:34–11:46 PM	npt-ws01	Registry Run-key persistence created (WindowsHealthCheck); scheduled task created (GoogleUpdaterTask); Windows service created via sc.exe (WindowsHealthSvc, binPath = WindowsUpdate.exe); discovery activity across shares, accounts, domain trusts; additional account manipulation.
11:35 PM – 1:53 AM	npt-ws01	Repeated brute-force / credential-access alerts, consistent with the attacker attempting to expand access using additional credentials.
11:37 PM	npt-ws01 / npt-srv01	Outbound C2 beaconing observed; DNS/network activity resolves to updates.abordasync.website.

- Red-shaded rows = activity on npt-ws01 (confirmed compromise).
- Amber-shaded rows = activity involving npt-srv01 (blocked lateral-movement attempt).

Note: source timestamps were drawn from multiple telemetry tables (AlertEvidence, DeviceProcessEvents, DeviceNetworkEvents); minor inconsistencies between local time and UTC-normalized query windows were observed during reconstruction. Recommend normalizing all sources to a single timezone standard in the final case record.

4. Impact & Scope

Host	Status	Notes
npt-ws01	COMPROMISED	Full attack chain: defense-evasion, execution, three persistence mechanisms, backdoor privileged account, discovery, credential access, outbound C2.
npt-srv01	ATTACK BLOCKED	Lateral-movement payload prevented by AMSI/Defender before execution. No persistence or account activity observed — still requires containment review.
npt-c2-01 / npt-linux01	REVIEWED – LOW CONFIDENCE	Unrelated or lower-confidence alert activity during scoping; not treated as confirmed incident scope pending further review.

- At least one legitimate account (helpdesk) confirmed compromised and used by the attacker; full scope of credential exposure from the brute-force/credential-access activity is not yet determined and requires follow-up.

- No confirmed data exfiltration identified in the evidence reviewed to date; the C2 channel's purpose (exfiltration vs. command channel only) should be confirmed through network traffic analysis.

5. Detection Point and Rationale

The second affected host was identified using the AlertEvidence table rather than authentication or network-connection logs, and this was a deliberate choice: because npt-srv01's compromise attempt was blocked, it produced no successful logon and no completed persistence artifacts — the very evidence that authentication and process-tree analysis rely on. AlertEvidence, however, records what the security stack detected and stopped, independent of whether the attacker's action succeeded. Aggregating AlertEvidence by DeviceName across the "npt-" fleet surfaced npt-srv01 as the only other host with a correlated cluster of alerts in the incident window.

The Category field (mapped to MITRE ATT&CK tactics) was then used as a maturity indicator for each candidate host: npt-ws01 shows the full chain (DefenseEvasion, LateralMovement, Persistence, Execution, Discovery, CredentialAccess, CommandAndControl), while npt-srv01 shows only the early stages (LateralMovement, DefenseEvasion, and a single CommandAndControl alert) with no Persistence, Execution, or Discovery alerts — the expected fingerprint of an attempt interrupted before establishing a foothold. This was corroborated by an explicit "prevented from executing" outcome on the AMSI-related alert, distinguishing it from the merely descriptive "Attempt to..." alert titles used elsewhere, which name a detection rule rather than assert an outcome.

6. Containment, Eradication & Recovery

The following actions translate the findings above into a concrete containment and remediation plan, organized per NIST SP 800-61r2. Checkboxes indicate discrete action items for the response team to track to completion.

6.1 Immediate Isolation Actions

- **npt-ws01 (primary, confirmed compromised):** Isolate immediately from the network (EDR network-isolation / disable switch port). This host shows a completed attack chain from initial access through C2 beaconing.
- **npt-srv01 (secondary, lateral-movement target):** Isolate as a precaution even though the deployment attempt was blocked. "Blocked" is not the same as "clean" isolate pending a full sweep.
- **Before isolating** capture volatile data (memory, running processes, network connections, scheduled tasks, services, registry Run keys) on both hosts for forensic preservation.
- **Network segment review:** confirm no further internal hosts were contacted from npt-ws01 during the incident window by reviewing DeviceNetworkEvents for all internal (RFC1918) destination IPs.

6.2 Accounts to Disable / Reset

- **helpdesk** — legitimate account used for the initial successful logon (source 20.110.92.50). Disable, force password reset, revoke active sessions/tokens, require MFA before re-enabling.
- **nexus_admin** — backdoor local account created and promoted to local Administrators. Disable and remove after evidence is collected on the creation event.
- **Local Administrators group (npt-ws01):** audit full membership for any other unauthorized additions beyond nexus_admin.
- **Domain-wide credential hygiene:** force reset for any accounts that authenticated to or from npt-ws01 during the incident window.

6.3 Indicators of Compromise to Block

Type	Indicator	Action
External IP	20.110.92.50	Block at perimeter firewall / conditional access; review VPN and RDP-gateway logs for other logons from this IP.
C2 Domain	updates.abordasync.website	Block at DNS/web proxy; add to threat-intel blocklist fleet-wide; hunt for any other host that resolved/beaconed to this domain.
Malicious binary	C:\Windows\Temp\WindowsUpdate.exe	Quarantine/delete; this path was both the dropped implant and the sc.exe service binPath.
File hash (SHA256)	20cef6a013953890f9d38605d25d60dd63b42b09946bbb18ddb4a456da306e77	Add as a custom indicator in EDR/AV to block execution and enable fleet-wide detection independent of filename or path.
Malware family	"Gracing"	Confirm AV/EDR signature coverage fleet-wide; this family triggered the LateralMovement detections (WinRM T1021.006, WMI T1047, DCOM T1021.003).
Internal pivot IP	10.3.0.10 (npt-srv01)	Not a perimeter block (internal host) — isolate the host itself and restrict

		RDP/WMI/RPC to it pending review.
Suspicious scripts	script19.ps1, script24.ps1	Search all hosts for these filenames on disk or in PowerShell operational logs; treat as staged tooling.

6.4 Persistence Mechanisms to Remove (npt-ws01)

- **Registry Run key:** WindowsHealthCheck under \CurrentVersion\Run — delete the value and its referenced binary.
- **Scheduled task:** GoogleUpdaterTask — delete via Task Scheduler / schtasks /Delete /TN, after capturing the task XML for evidence.
- **Windows service:** WindowsHealthSvc — stop and delete (binPath pointed at WindowsUpdate.exe; DisplayName "Windows Health Service" masquerading as legitimate).
- **Backdoor local account:** nexus_admin — remove from Administrators group and delete.
- **Defender/AMSI tampering:** verify Defender is fully re-enabled, real-time protection is on, and remove any exclusion paths the attacker added (likely covering C:\Windows\Temp).
- **WMI persistence check:** audit for WMI permanent event subscriptions (__EventFilter / __EventConsumer / __FilterToConsumerBinding) on both hosts, since WMI was used for both execution and lateral movement.

6.5 Eradication

- Terminate the malicious process(es) and the WindowsHealthSvc service on npt-ws01.
- Delete C:\Windows\Temp\WindowsUpdate.exe and any dropped output artifacts (e.g., \Windows\Temp\uYgvso).
- Remove the registry Run key, scheduled task, service, and backdoor account listed above.
- Given the depth of compromise on npt-ws01 (full persistence + credential access + C2), reimage rather than manually clean if business impact allows, to guarantee no residual foothold.
- On npt-srv01: confirm via full EDR scan and manual review that no persistence artifacts exist despite the blocked deployment — the RunScript attempt reached the host even though AMSI stopped execution.

6.6 Recovery

- Return hosts to production only after isolation controls are lifted, persistence artifacts are confirmed removed, and credentials are rotated.
- Reset the helpdesk account password and any credentials that authenticated on npt-ws01 during the incident window; enforce MFA going forward.
- Harden exposed remote-access paths: review why RDP and WMI/RPC were reachable/usable for lateral movement between npt-ws01 and npt-srv01; restrict via segmentation or JIT access.
- Place npt-ws01 and npt-srv01 under heightened monitoring for 30 days post-recovery, alerting on recurrence of the identified IOCs.

7. Post-Incident Follow-Up

- Feed all IOCs (IP, domain, file hash, account names, persistence artifact names) into the organization's threat-intel/blocklist platform.
- Update detection content to alert on the specific technique chain observed (WMI-initiated remote cmd.exe launch, sc.exe service creation with suspicious binPath, AMSI-prevented lateral RunScript) as a correlated high-confidence detection.
- Conduct a lessons-learned review covering how the helpdesk account was initially compromised (e.g., phishing, credential stuffing, exposed remote-access portal) to close the true initial-access gap.
- Priority follow-ups: confirm root cause of the helpdesk account compromise, determine the full extent of credential exposure from the brute-force activity, and complete a forensic sweep of npt-srv01 to close out its status with full confidence.